

IT Security Policy/Procedures

Introduction

With recent opportunities to expand the company and open the doors to international clients in Europe and North Africa, the company is getting ready to handle a increase in revenue, workload, and overall maintain on the right path to grow the company further. With everything cause and effect must take place, with the expansion, the company is more susceptible to risks that can be easily avoided or minimized. The purpose of this document is to outline the risks introduced, recommended mitigation strategies, and legal considerations to ensure all sensitive data remains accessible only to those part of the company.

Key Risks

1. **Intellectual Property Exposure:** Proprietary data used in demonstrations can be replicated or stolen during travel.
2. **Device Security:** Portable devices (i.e. Tablets,Laptops, phones,etc) are at risk of theft, malware infections, or compromise via unsecured networks.
3. **Employee Security:** Personnel are susceptible to social engineering scams, phishing scams, or surveillance while travelling including should peaking or piggybacking.
4. **Insider Threats:** Employees left unmonitored or unsupervised, can lead to unintentional or deliberate access muses or oversharing sensitive information.
5. **Legal/Regulatory:** Noncompliance with foreign or U.S. data laws can lead to heavy fines and reputational damage.
6. **Weak Access Controls:** Lack of user restrictions may allow bad actors to have full access to company systems in the event of a system breach.

Legal Considerations

1. **European Considerations:**
 - a. General Data Protection Regulation (GDPR): Requires strict data control (i.e personal data, data encryption, consent management, or breach notifications)
 - b. Markets in Financial Instruments Directive (MiFID): European regulation mandating a company maintains secure recordkeeping and transaction integrity for any and all clients.
 - c. General Product Safety Regulation (GPSR): Mandates digital products demonstrate and meet safety compliance standards.
2. **North African Considerations:**
 - a. Different data encryption and storage standards, and data transfer which may conflict with U.S. practices due to varying laws.

- b. Companies must confirm encryption is permitted, whether data is stored locally or legally allowed monitoring systems.
- 3. **United States Considerations:**
 - a. International Traffic in Arms Regulations/Export Administration Regulation (ITAR/EAR): Places a limit on what technical information can be shared internationally.
 - b. Federal Information Security Modernization Act/National Institute of Standards and Technology (FISMA/NIST): Provides guidance when handling federal and commercial client data securely.

Mitigation Strategies

1. **Concern:** Intellectual Property Exposure
 - a. **Correction:** Restrict access to demo products to a need to know basis. Meaning only show what the client is looking for, nothing more, and encrypt any and all files not being used along with watermarking to prevent piracy.
2. **Concern:** Device Security
 - a. **Correction:** Implement Multi-factor authentication software and VPN usage to all company devices. This prevents bad actors from logging into employee accounts should their device be stolen.
3. **Concern:** Employee Security
 - a. **Correction:** Provide mandatory cybersecurity training including phishing awareness, secure device use, and reporting procedures.
4. **Concern:** Insider Threats
 - a. **Correction:** Implement role based access controls and monitor the activity with Security Information and Event Management (SIEM) to flag suspicious behavior.
5. **Concern:** Legal/Regulatory Standards
 - a. **Correction:** Establish a compliance review team to monitor international engagements and ensure adherence to both local and international data laws (e.g., GDPR, ITAR, and regional encryption requirements).
6. **Concern:** Weak Access Control
 - a. **Correction:** Conduct quarterly audits of all user accounts and permissions. Enforce least-privilege principles, require strong password policies, and mandate multi-factor authentication for all system logins to prevent unauthorized escalation of access.

Conclusion

With recent, current, and future expansion opportunities, intellectual property, client data, and company reputation must remain at the top of the priority list which relies heavily on strong IT security policies. With the proper security policies such as strict access controls, complying with international regulations, and employee training, the company will minimize their exposure and keep operations running securely.